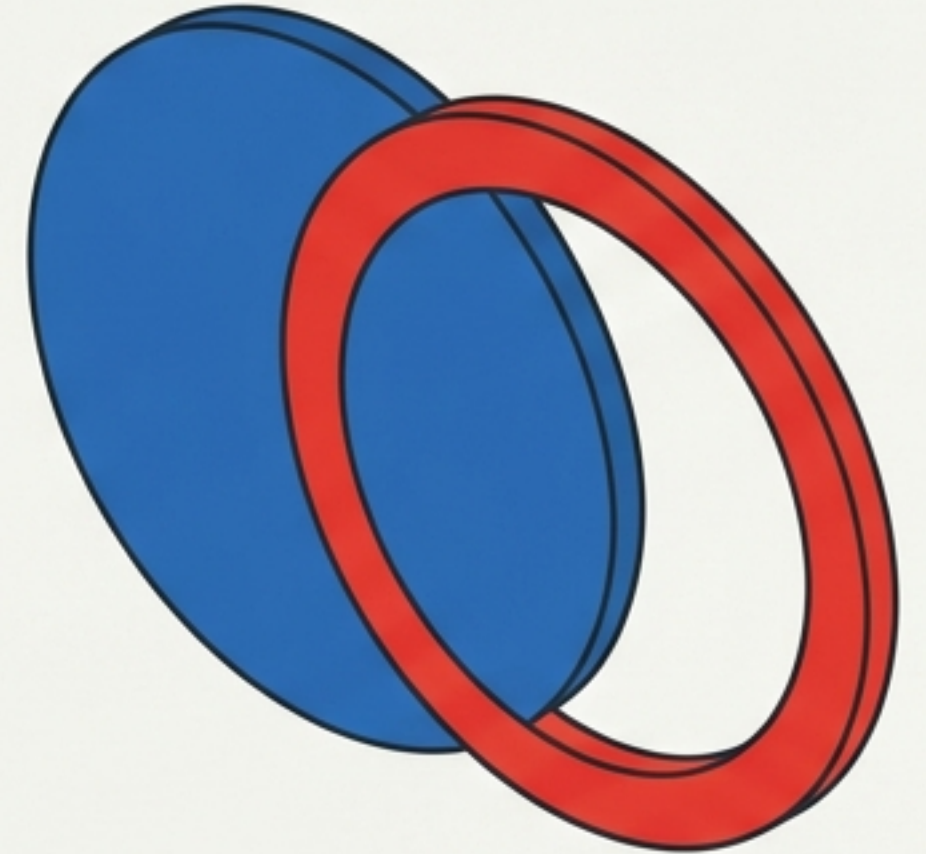


Google Gemini in Workspace: GDPR Compliance & Data Rights

Navigating Deletion and Correction
Risks for Enterprise



The Executive Summary: The Governance Gap



THE RISK

The inability for Workspace administrators to granularly delete individual Gemini chat sessions creates a specific GDPR risk profile regarding Article 17 (Erasure) and Article 16 (Rectification). This is a high-impact governance risk.



THE CONSTRAINT

Google's architecture prioritizes global retention policies over specific record deletion. Admins can set broad time windows (e.g., 18 months), but cannot technically execute a targeted deletion of a single chat record.



THE SOLUTION

Compliance is achieved not by changing the code, but by:

1. Shortening retention windows (Configuration).
2. Restricting PII input (Policy).
3. Using 'Supplementary Statements' (Operational Workflow).

The 'Two Geminis' Distinction Determines Liability

(A) Gemini in Workspace Apps

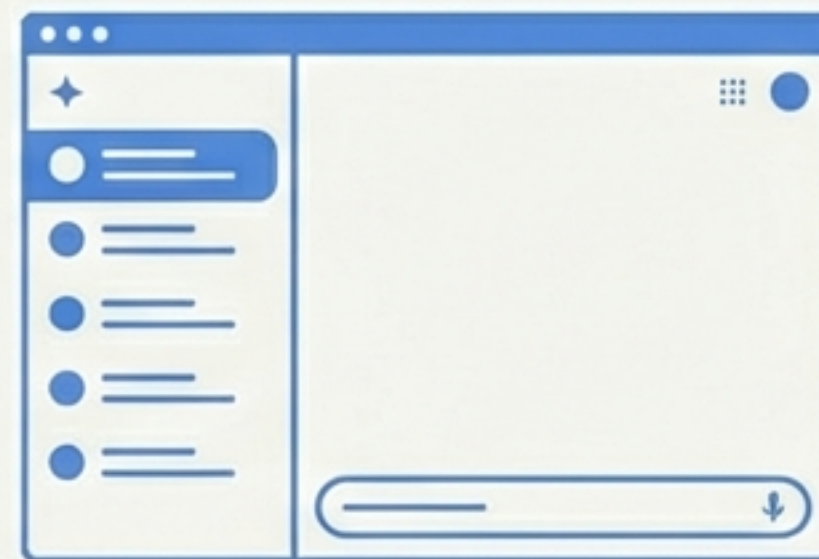
Docs, Drive, Gmail side panel



- **Data State:** Ephemeral
- **Lifecycle:** Disappears after session ends
- **Governance:** Managed by standard Vault/Drive policies

(B) The Standalone Gemini App

Accessed via gemini.google.com

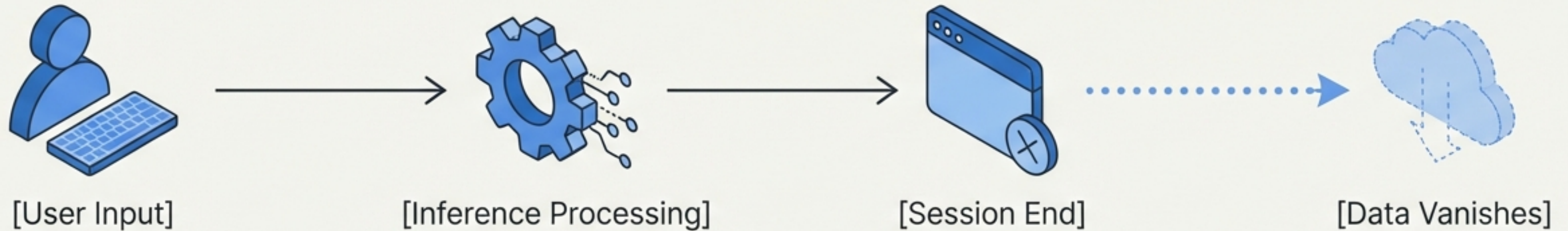


- **Data State:** Persistent
- **Lifecycle:** Saved to Conversation History (Default 18 Months)
- **Governance:** Managed by specific Gemini Admin settings

CRITICAL INSIGHT: This deck focuses on Column B, where persistent data creates the retention risk.

The Data Lifecycle: Where Liability Sits

Workspace Apps (Docs/Gmail)



Standalone Gemini App



The Legal Standard: Articles 16 & 17

Article 17: Right to Erasure

The right to delete data “without undue delay.”

Constraint: Exceptions exist (e.g., legal obligation), but “technical inconvenience” is not a valid exception.



Article 16: Right to Rectification

The right to correct inaccurate personal data (e.g., AI hallucinations).

Mechanism: Includes providing a ‘supplementary statement’ to complete incomplete data.

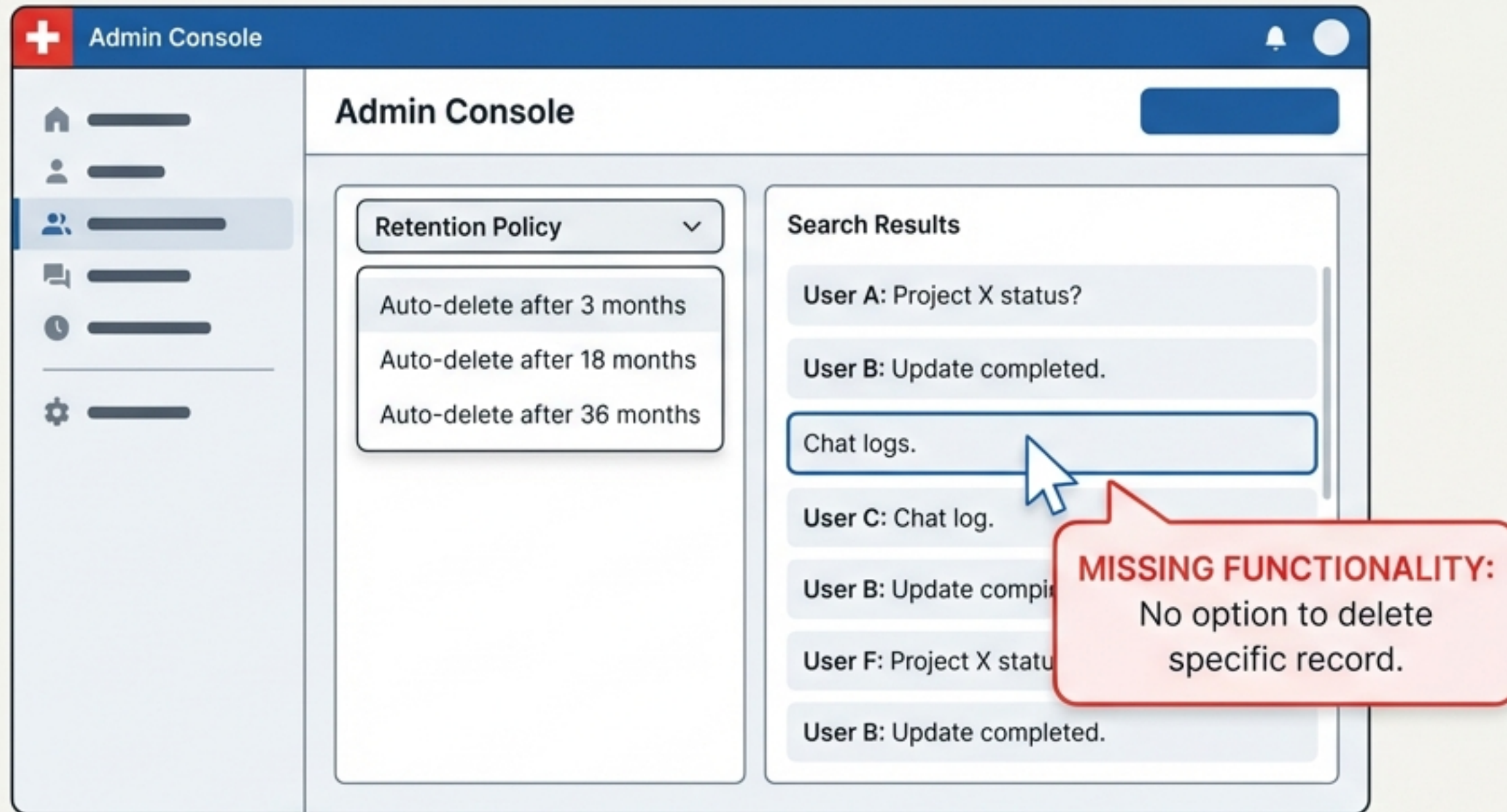


Article 5: Storage Limitation

Data must be kept “no longer than necessary.” Defaulting to 18 months without a specific purpose violates this principle.



The Compliance Gap: Admins Cannot Granularly Delete



The Consequence: If a valid Article 17 request arrives today, an admin cannot technically “click delete” on that specific record without purging data globally or waiting for the auto-delete window.

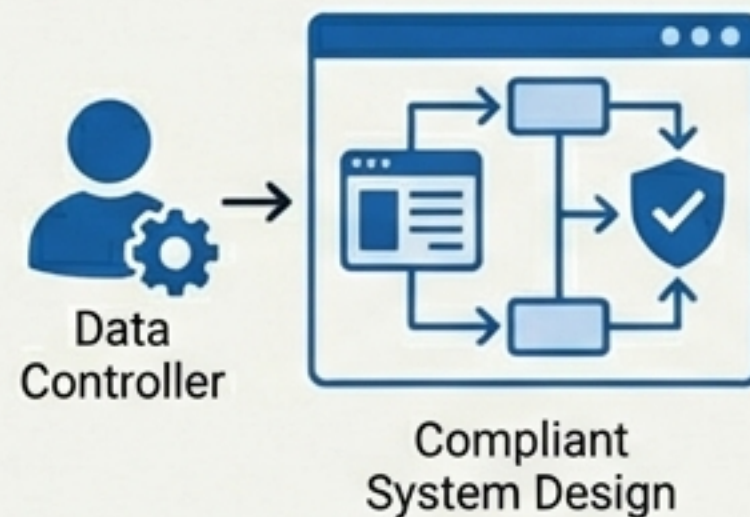
The ‘Technical Impossibility’ Fallacy

“*Technical impossibility cannot be invoked to justify non-compliance.*”

— EDPB ChatGPT Taskforce Report

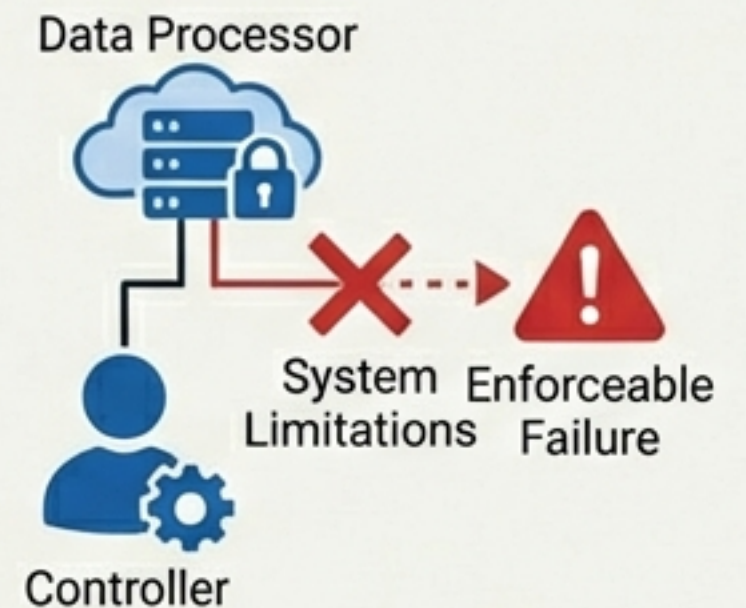
Data Protection by Design:

Controllers must choose systems that make rights fulfillment achievable.



Article 28(3)(e):

Processors (Google) must assist controllers “insofar as possible.” Relying on “system limitations” elevates risk from technical annoyance to enforceable failure.



Role Analysis: When Does Risk Explode?

Scenario A: Core Service

Status: Enterprise Editions

Role: Customer is Controller; Google is Processor.

Data Use: Data is NOT used to train Google models.

Risk Level: Managed Governance.

Scenario B: Additional Service

Status: Unlicensed / Consumer Settings

Role: Google may act as Controller or Joint Controller.

Data Use: Data IS used to train models (includes human review).

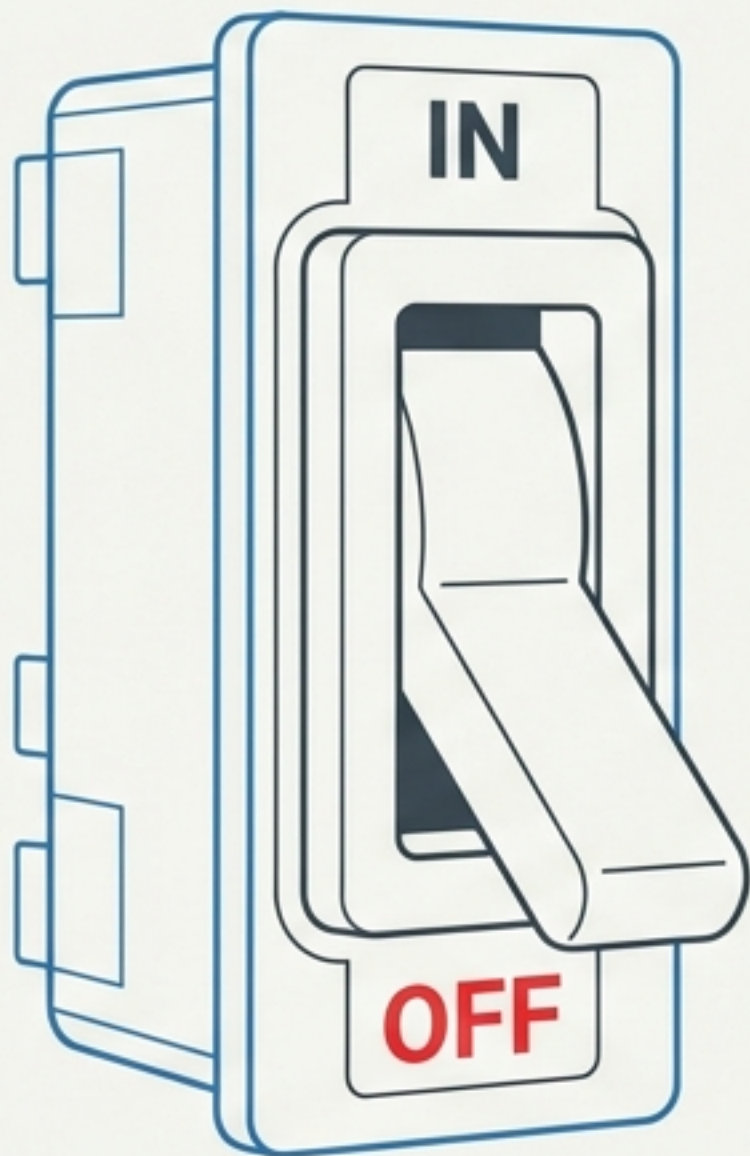
Risk Level: High Liability.

Case Law Warning: *Wirtschaftsakademie* ruling suggests platform constraints do not absolve the organization of joint responsibility.

Risk Assessment Heatmap

HIGH RISK	Retention: 18 Months (Default) Service Mode: Additional Service (Consumer Terms) Input: Sensitive/PII allowed in prompts.
MEDIUM RISK	Retention: 18 Months Service Mode: Core Service (Enterprise) Constraint: Admin cannot delete individual chats; friction with Art. 17.
LOW RISK	Retention: History OFF (72-hour retention) Service Mode: Core Service Policy: Strict PII ban.

Mitigation Strategy 1: Configuration & Retention



The Principle: If you don't store it, you don't have to delete it.

Recommendation A (Strongest): Turn Conversation History OFF.

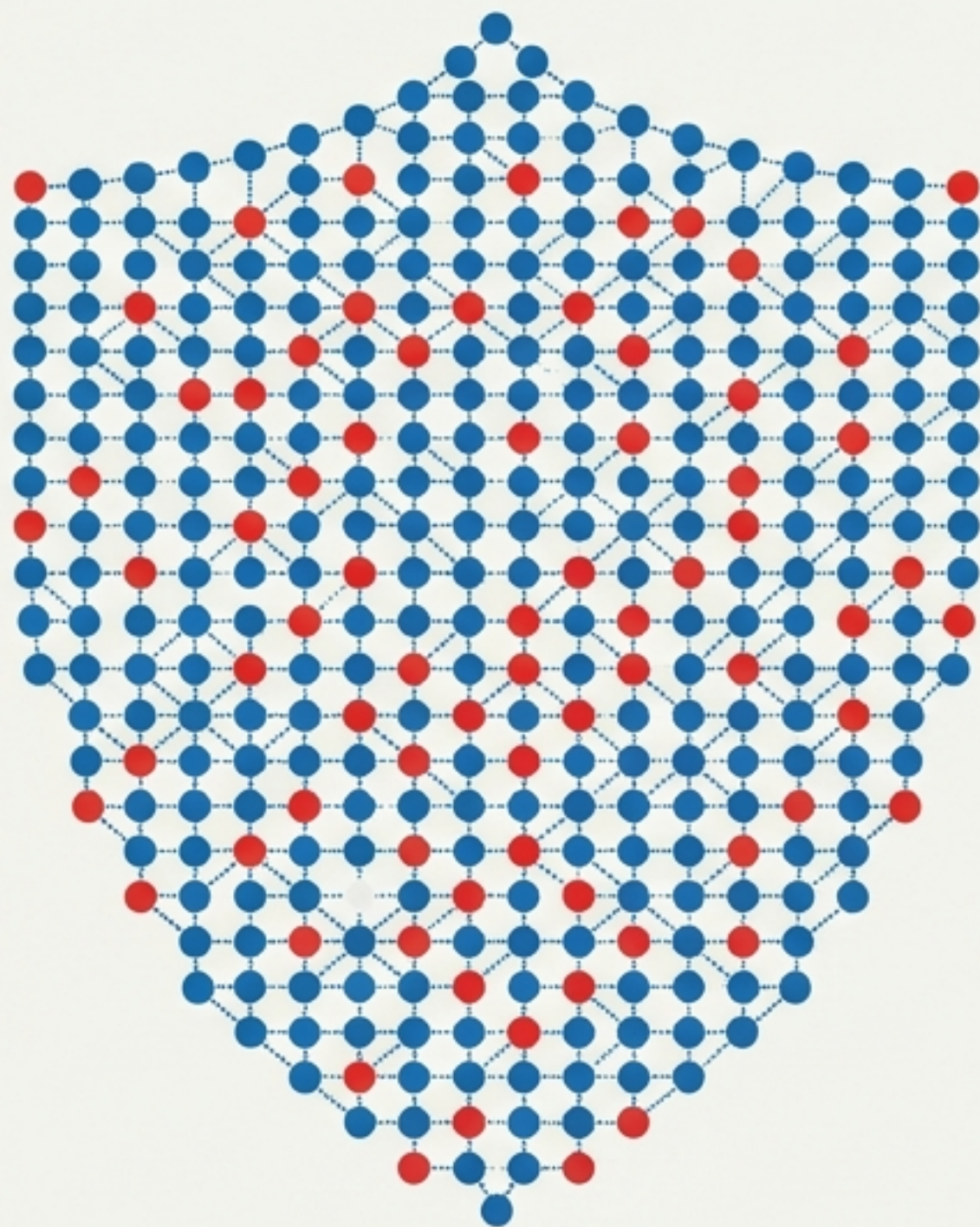
- **Result:** Chats saved for only 72 hours for processing, then purged.
- **Impact:** Eliminates long-term storage liability.

Recommendation B (Balanced): Shorten Retention to 3 Months.

- **Result:** Reduces exposure window from 1.5 years to 90 days.

Warning: Settings are not retroactive. Existing history remains stored for the previously defined period.

Mitigation Strategy 2: The Human Firewall



1. Update Acceptable Use Policy

- Rule: Do not enter PII, HR data, or sensitive customer details into prompts.

2. The “Public Postcard” Mindset

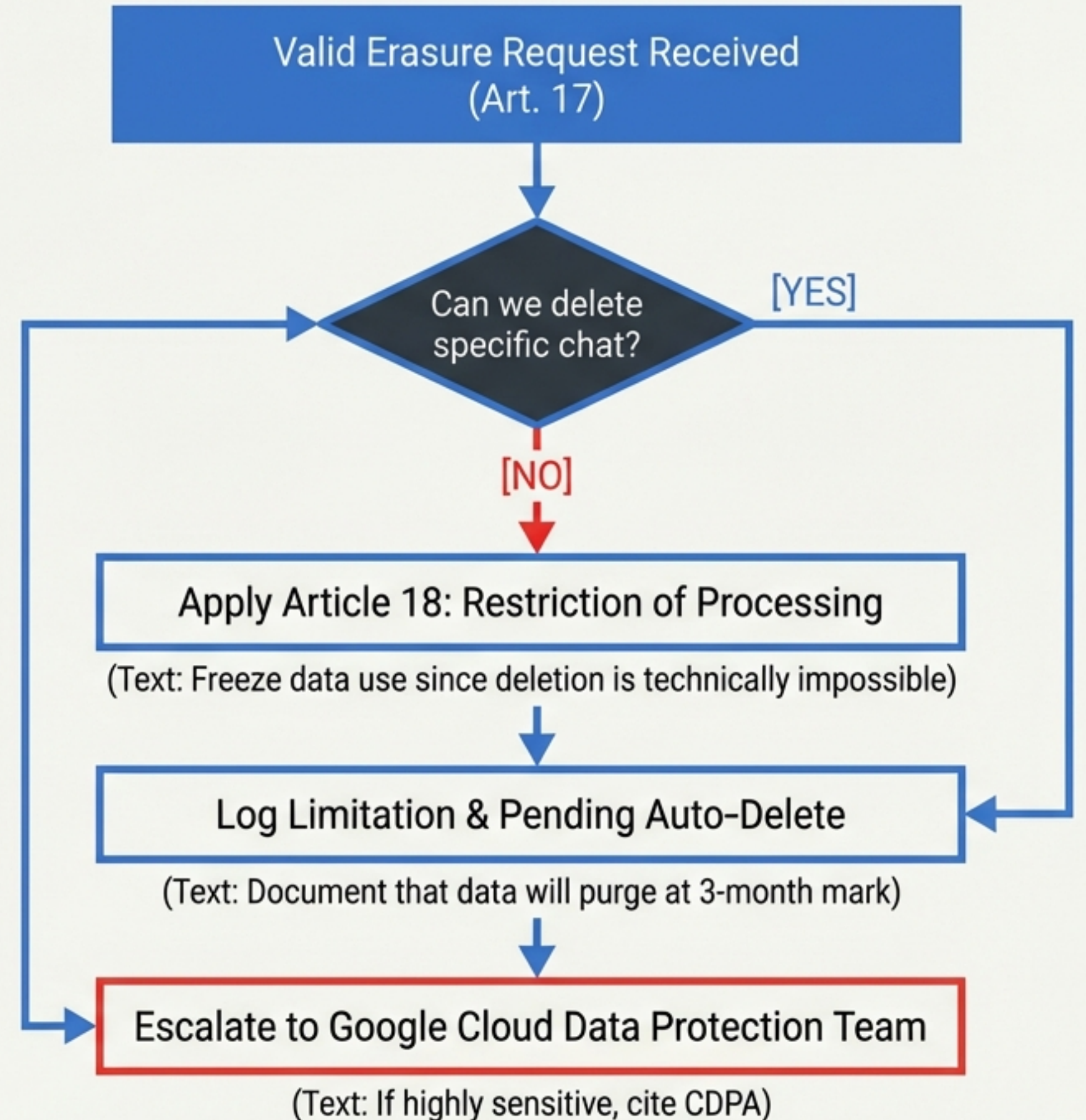
- Training Concept: Treat prompts like public postcards, not private vaults.

3. Just-in-Time Guidance

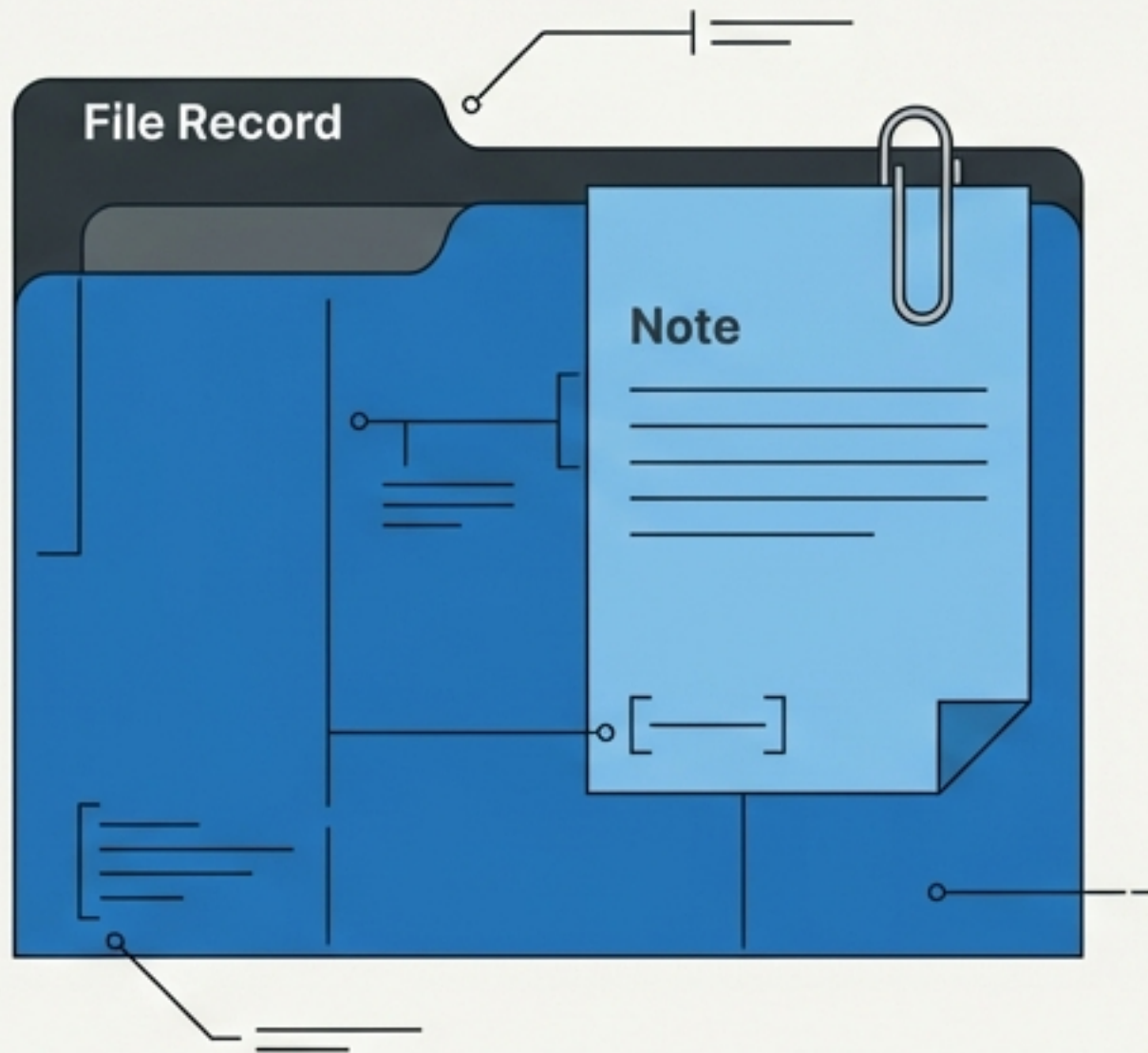
- Deployment: Remind users that "Prompt text is data processing" at the point of entry.

Effect: Reduces the likelihood that an Erasure request will ever target a chat log.

Mitigation Strategy 3: The DSAR Workflow



Handling Rectification & Hallucinations



The Problem

Gemini produces inaccurate personal data ('Hallucination').

You cannot edit the AI's transcript source code.

The Solution

The 'Supplementary Statement' Fix (Art. 16)

- Do not rewrite memory. Append a note to the HR/Customer file:
"The Gemini record dated [Date] contains errors regarding [Topic]."
- Use Google's 'Report Legal Issue' tool for specific Gemini responses.

Immediate Recommendations Checklist

01. AUDIT IDENTITY

Confirm if you are using “Core Service” (Enterprise) or “Additional Service” (Consumer).

02. CONFIGURE RETENTION

Move from default (18 months) to 3 months or OFF.

03. UPDATE POLICY

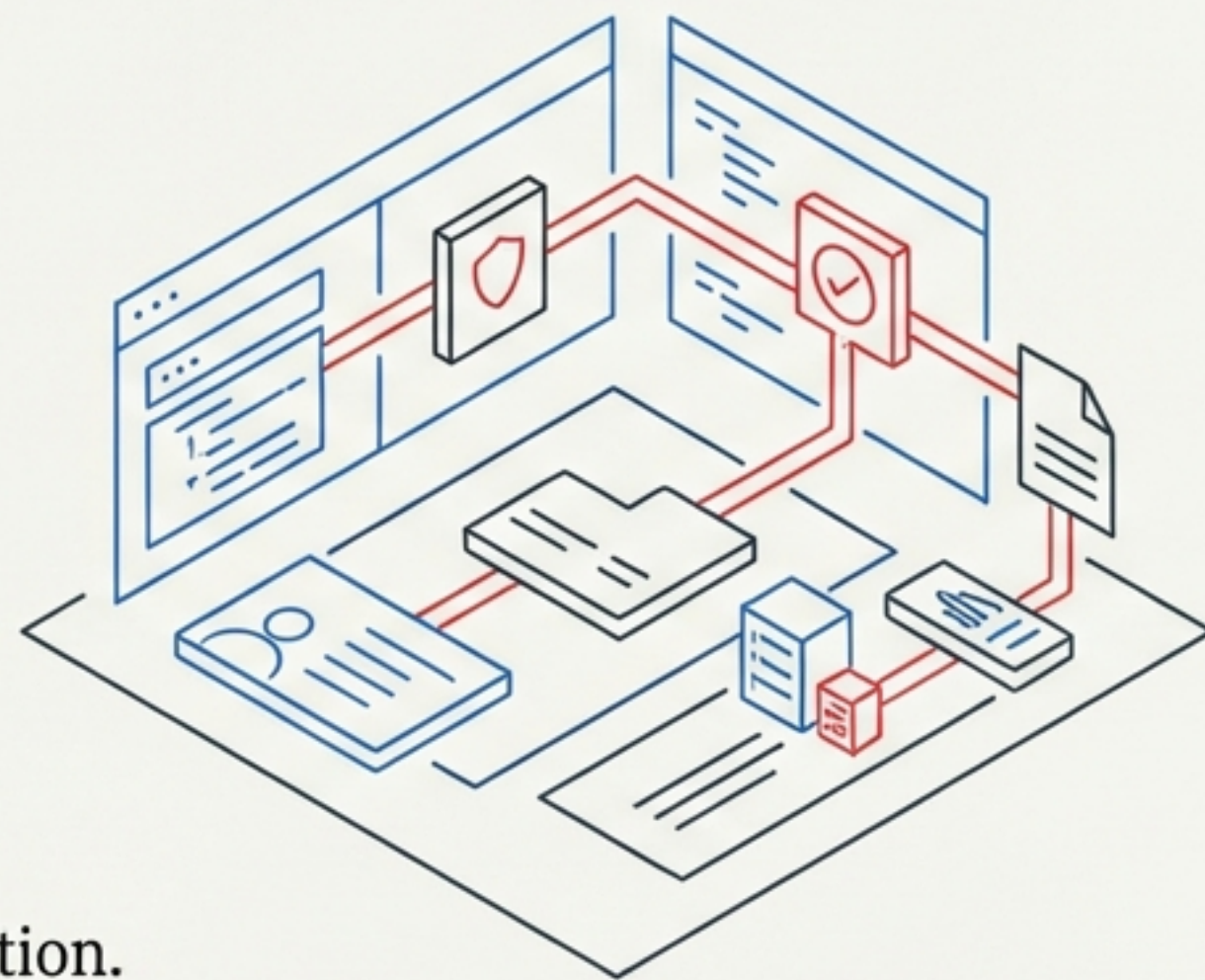
Explicitly ban PII in prompts in the Employee Handbook.

04. DRAFT PLAYBOOK

Create the “Impossible Deletion” protocol using Article 18 Restriction.

05. REVIEW VENDORS

If high-risk processing is required, reconsider tools that lack granular deletion.



Conclusion: Governance Over Perfection

The inability to delete individual chats is a governance risk, not an automatic breach.

- - Demonstrate control through settings.
- - Demonstrate accountability through policy.
- - Demonstrate responsiveness through documented workarounds.

‘Rights enforcement must be operationalised, not sidelined as an engineering inconvenience.’